PROJECT-WORK · CORSO AI/CV

Valerio Querzoli · Unimore

# Un IDS *ibrido* per il traffico di rete

Classificazione supervisionata + autoencoder

IL PROBLEMA

*Un classificatore riconosce solo gli attacchi che ha già visto.*

OBIETTIVI

1. Riconoscere gli attacchi noti
2. Segnalare quelli mai visti (zero-day)
3. Misurare onestamente quanto aiuta il secondo livello

Valerio Querzoli · Unimore

# Dati: CIC-IDS2017 e *pulizia*

PACCHETTI



CICFlowMeter →

UN FLUSSO = UNA RIGA DI NUMERI

durata | byte → | byte ← | tempo tra pacchetti | flag SYN | ... | etichetta

77 FEATURE PER FLUSSO · LE FAMIGLIE PRINCIPALI

**Tempi**
durata, intervalli tra pacchetti, pause

**Volumi e dimensioni**
pacchetti e byte per direzione

**Velocità**
byte/s e pacchetti/s

**Flag TCP**
SYN, FIN, RST, ACK...

DATASET

## 2,3 milioni

flussi, rete di laboratorio

PULIZIA

## 2.143 + 2.843

righe corrotte, corrette o rimosse

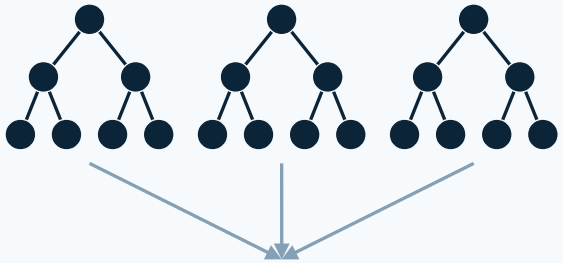
SPLIT 60 / 20 / 20

## 1.386.580

train · 462.193 val · 462.194 test

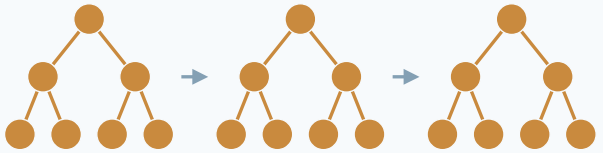
Valerio Querzoli · Unimore

# Tre modelli, due modi di *imparare*



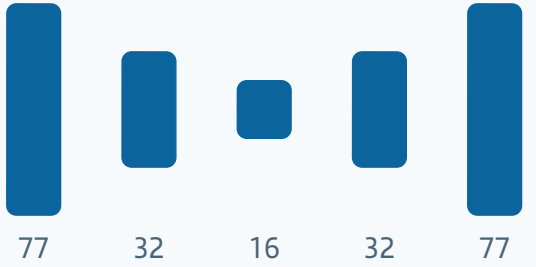

## Random Forest

Molti alberi di decisione indipendenti: ognuno vota, vince la maggioranza. Usato come baseline.




## XGBoost

Alberi in sequenza: ognuno corregge gli errori del precedente.




× 2: feature grezze e in scala log

## Autoencoder

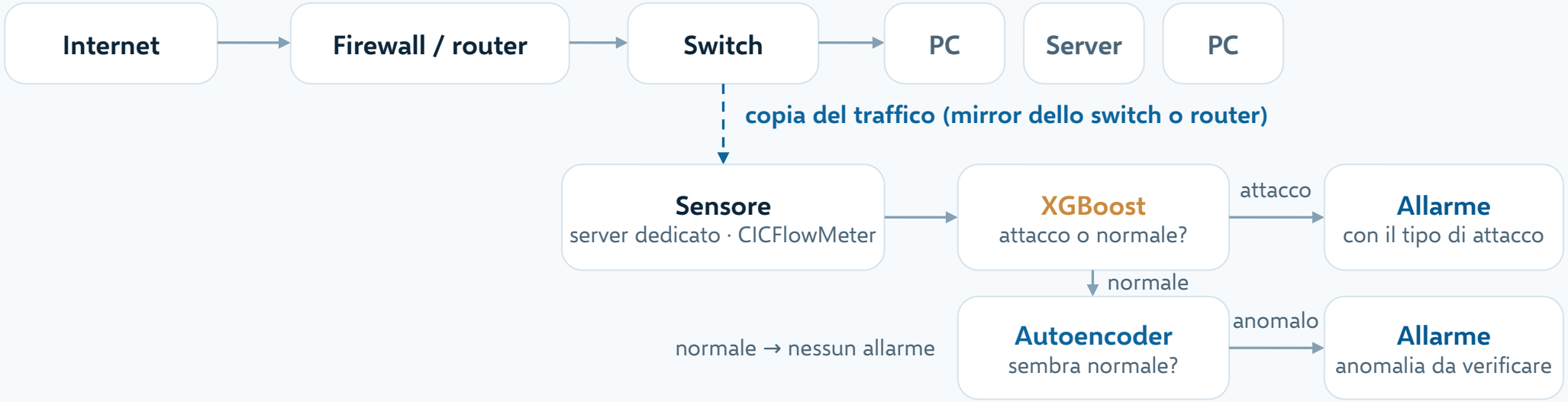
Due reti neurali che comprimono e ricostruiscono il traffico normale: errore alto = anomalo.

*RF e XGBoost imparano gli attacchi. L'autoencoder impara solo il traffico normale.*

Valerio Querzoli · Unimore

# XGBoost + autoencoder, *in cascata*

## DOVE SI COLLOCA




## TRAINING E VALIDAZIONE

### NEL PROGETTO

Analisi offline di flussi registrati: CIC-IDS2017 e cattura al router della simulazione Docker. Non in tempo reale.

### XGBOOST

binario attacco / normale, senza l'attacco escluso

### AUTOENCODER

2 modelli, solo Benign, soglia p99 ≈ 1% falsi allarmi

Valerio Querzoli · Unimore

# Come ho testato, e cosa è *emerso*

IL TEST

*Escludo un'intera famiglia di attacchi dal training, poi la cerco nel test set.*

FAMIGLIA DOS · 64.317 CASI (TEST)

**18,1% → 74,7%**

XGBoost solo → + AE · 5 seed: 74,1 ± 0,5%

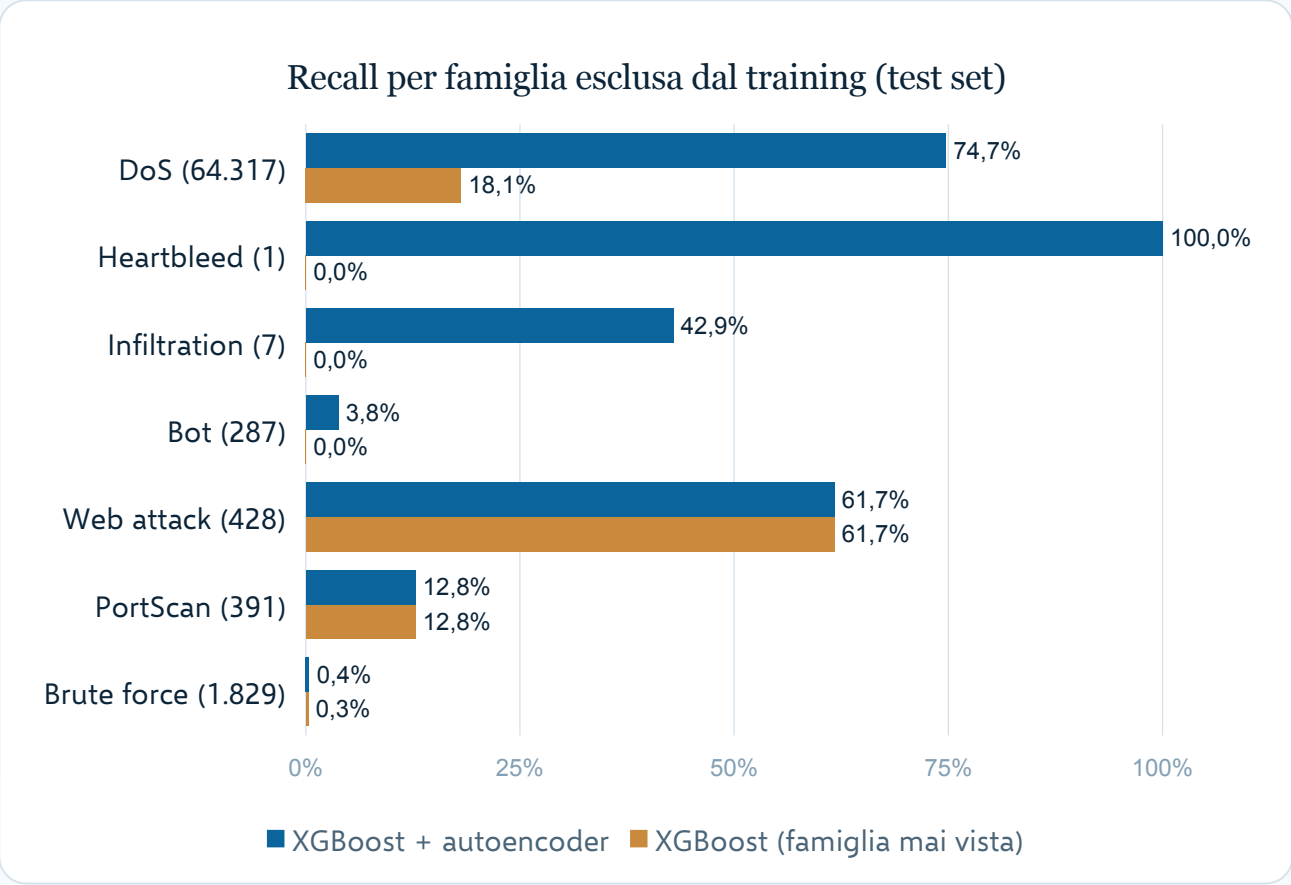
**≈ +1% falsi allarmi**

3.944 su 394.934 flussi normali

CONTROLLO IN-DOMINIO (TEST)

**97,9% → 98,4%**

l'autoencoder serve solo per lo zero-day



Valerio Querzoli · Unimore

# Pro e *contro*

## *Pro*

- Recupera zero-day volumetrici
- Autoencoder leggero e veloce
- Soglia regolabile sui falsi allarmi

## *Contro*

- Circa +1% di falsi allarmi
- AE non aiuta su scan, brute force, bot
- Va allenato per ogni rete

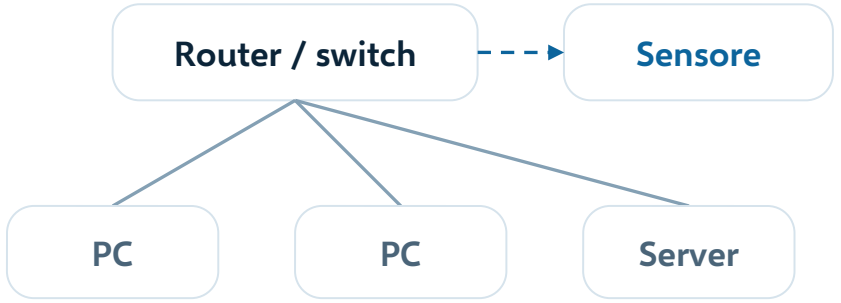
DIFFICOLTÀ INCONTRATE

**Bug nel dataset** | **Bug di CICFlowMeter** | **Cattura duplicata** | **Classi sbilanciate**

Valerio Querzoli · Unimore

# IDS di rete e EDR: due *punti di vista*

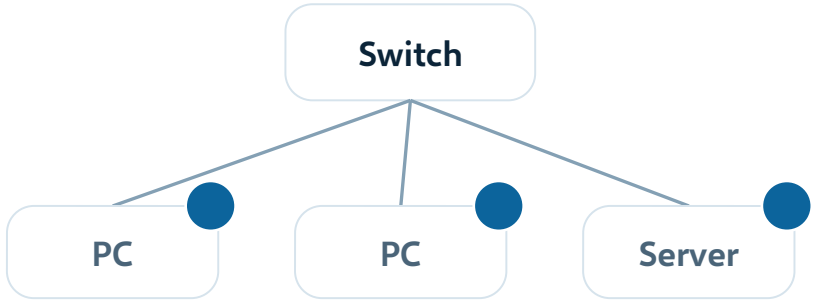
## *IDS di rete · questo progetto*




**Vede:** tempi, dimensioni, flag TCP

**Non vede:** il contenuto dei pacchetti (payload)

## *EDR · un agente su ogni host*




**Vede:** processi, utenti, payload decifrato

CrowdStrike · SentinelOne · Defender

SIMULAZIONE DOCKER

*31 container, 39.781 flussi, 28 episodi — banco di prova, non traffico reale*

Valerio Querzoli · Unimore

# Zero-day, limiti e *conclusione*

COME VIENE VISTO UNO ZERO-DAY

**Reso visibile, non risolto**
Diventa un allarme da verificare, non una classificazione certa.

**Anomalia, non attacco**
Anche traffico legittimo mai visto fa scattare l'allarme.

LIMITI

Trasferimento tra reti · un flusso alla volta (niente pattern nel tempo) · solo livello di rete

## Un secondo livello non sostituisce il classificatore: recupera minacce specifiche che il classificatore manca, a un costo di falsi allarmi misurato.

**Grazie — domande? →**